You said:

exec.out
File

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 1m 11s >

ChatGPT said:

Análise de malware — `exec.out`

Veredito: MALWARE

Confiança da classificação: muito alta, com base na análise estática do executável.

O arquivo `exec.out` apresenta evidências claras de um **bot de DDoS controlado remotamente por IRC, com funcionalidades de backdoor e download de arquivos**. Seu código é compatível com a família **Kaiten/Tsunami**, conhecida por utilizar máquinas comprometidas para realizar ataques distribuídos de negação de serviço. Essa identificação é consistente com análises publicadas por empresas de segurança. 【turn619400search2】【turn619400search4】

A análise abaixo foi realizada sem executar o arquivo.

1. Identificação do arquivo

Primeiro, examinei os metadados e o cabeçalho binário.

Propriedade	Resultado
Nome	`exec.out`
Tamanho	41.072 bytes (aprox. 40,1 KiB)
Formato	ELF 64 bits
Arquitetura	x86-64
Plataforma	Linux
Tipo de executável	PIE, dinamicamente vinculado
Bibliotecas	`libc.so.6`

Símbolos de depuração	Presentes
SHA-256	`3d5b7f663a3654a699c0512d54762a9a8d4b1adcdaaddacdc8784f87df9c66a3`

O formato ELF, isoladamente, não indica comportamento malicioso. Ele apenas confirma que se trata de um executável nativo para sistemas compatíveis com Linux.

2. Inspeção das funções e dos símbolos

A inspeção dos símbolos revelou nomes que indicam funcionalidades específicas:

`main`, `con`, `_PRIVMSG`, `udp`, `pan`, `tsunami`, `unknown`, `spoof`, `get`, `disable` e `enable`.

Esses nomes não são suficientes, por si só, para condenar um arquivo. Entretanto, quando combinados com as strings internas e o código desmontado, formam um conjunto consistente de capacidades maliciosas.

3. Comportamento de inicialização e ocultação

Na função `main`, identifiquei as seguintes operações:

- O programa chama `fork()` e encerra o processo original quando a bifurcação é bem-sucedida.
- Substitui o conteúdo de `argv[0]` por `-bash`.
- Limpa os argumentos restantes da linha de comando.

A substituição de `argv[0]` pode fazer o processo parecer um shell comum em determinadas ferramentas de monitoramento.

Esse comportamento é um indício de **tentativa de disfarçar a identidade do processo**. Não demonstra, por si só, persistência após reinicialização; essa capacidade não deve ser presumida com base nesses comandos.

4. Comunicação com servidores remotos

O executável contém as seguintes strings de servidores IRC:

- `irc.qeast.net`
- `irc2.magic.ca`
- `irc.east.gblx.net`

- `irc.west.gblx.net`

Também foram identificadas as funções `con()` e `Send()`, além de rotinas de tratamento de mensagens IRC como `_PRIVMSG` e `_PING`.

O código inclui operações de rede para criar sockets, resolver nomes e conectar-se a servidores. Além disso, contém comandos típicos de um cliente controlado remotamente.

A interpretação é que o programa foi projetado para se conectar a uma infraestrutura de comando e controle (C2), receber instruções e executar ações determinadas por um operador remoto.

Os servidores acima são indicadores extraídos do arquivo; sua disponibilidade e eventual propriedade atual não foram verificadas.

5. Identificação das funcionalidades de DDoS

Este é o indício mais decisivo da análise.

O binário possui funções específicas para gerar diferentes tipos de tráfego de ataque.

Função	Capacidade identificada
`udp()`	Geração de tráfego UDP de inundação
`pan()`	Inundação SYN, associada a ataques contra conexões TCP
`tsunami()`	Rotina de inundação de pacotes TCP
`unknown()`	Outra rotina de inundação UDP, com tratamento diferente de falsificação de origem
`spoof()`	Configuração de endereços IP de origem falsificados

As strings internas confirmam essas interpretações. Por exemplo, a ajuda embutida descreve `UDP` como um flooder UDP e `PAN` como um flooder SYN.

Essas rotinas são coerentes com um malware que transforma o equipamento infectado em parte de uma botnet, capaz de gerar tráfego contra sistemas indicados pelo controlador remoto.

Um DDoS procura esgotar recursos ou capacidade de rede do alvo, prejudicando sua disponibilidade.

6. Verificação de comandos remotos

O arquivo contém uma lista de comandos de controle remoto:

Comando encontrado	Finalidade identificada
`TSUNAMI`	Acionar uma rotina de inundação
`PAN`	Acionar o flooder SYN
`UDP`	Acionar o flooder UDP
`UNKNOWN`	Acionar outra rotina de inundação
`NICK e SERVER`	Alterar parâmetros da conexão IRC
`SPOOFS e GETSPOOFS`	Configurar e consultar parâmetros de falsificação de IP
`DISABLE e ENABLE`	Desativar e reativar a geração de tráfego
`KILL e KILLALL`	Encerrar processos do programa ou processos de ataque
`MOVE`	Mudar o servidor de conexão
`IRC`	Enviar comandos IRC
`SH`	Executar comandos de shell
`GET`	Baixar arquivos a partir de um endereço HTTP
`VERSION e HELP`	Consultar versão e ajuda do programa

A simples presença desses textos poderia ser explicada em parte por um programa de administração ou teste. Entretanto, aqui eles correspondem a funções efetivamente presentes no binário.

Evidência de execução de comandos do sistema

A função `_PRIVMSG` contém referências a `popen()`, `fgets()` e `pclose()`. O código associado ao comando `SH` usa essa estrutura para executar comandos e tratar sua saída, que pode ser enviada de volta pela conexão IRC.

Isso representa uma capacidade de **execução remota de comandos**, característica de uma backdoor.

Evidência de download de arquivos

A função `get()` contém operações de conexão HTTP, envio de uma requisição `GET` e gravação de dados recebidos em um arquivo.

Assim, o operador pode instruir o programa a buscar conteúdo externo e salvá-lo no sistema comprometido. Essa funcionalidade poderia ser usada para introduzir outros componentes maliciosos.

7. Comparação com a família Kaiten/Tsunami

A classificação como Kaiten/Tsunami é sustentada pela combinação de várias características:

- A string distintiva `Kaiten wa goraku.`
- Os comandos IRC usados para administrar o cliente.
- As funções especializadas em ataques UDP, SYN e TCP.
- A configuração de endereços IP falsificados.
- A possibilidade de executar comandos de shell e baixar arquivos.

Essas características coincidem com descrições técnicas da família Kaiten, também conhecida como Tsunami, documentadas por empresas de segurança.
【turn619400search1】【turn619400search5】

A evidência é suficiente para identificar o tipo de malware com alta confiança. Contudo, não permite atribuir com segurança esta compilação a uma variante específica ou a um grupo criminoso determinado.

8. Avaliação consolidada

Evidência forte: ataques de negação de serviço
Funções de flood específicas, comandos de ataque e configuração de falsificação de IP.

Evidência forte: controle remoto
Comunicação IRC com tratamento de mensagens e comandos para controlar o programa.

Evidência forte: backdoor e downloader
Execução de comandos de shell e capacidade de baixar arquivos via HTTP.

Limitação: análise estática

Não foi testada a comunicação real com os servidores nem observado o comportamento em execução. Isso não altera a conclusão sobre as capacidades maliciosas presentes no código.

Conclusão final

O arquivo `exec.out` é um malware, não um programa benigno.

Sua categoria principal é **bot de DDoS controlado por IRC (cliente de botnet)**, com alta compatibilidade com a família **Kaiten/Tsunami**. A execução remota de comandos e o download de arquivos também lhe conferem características de backdoor.

O risco fundamental é que um sistema infectado possa ser controlado remotamente para atacar outros dispositivos e executar comandos não autorizados. Recomendo não executar o arquivo em um sistema real e, caso tenha sido encontrado em uma máquina, preservá-lo para análise e verificar possíveis indicadores de comprometimento.

Posso também criar um diagrama visual do fluxo de funcionamento deste malware: ↪ Ver diagrama do malware

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Botnet de DDoS (Distributed Denial of Service)**, da família **Kaiten/Tsunami**.

Ele utiliza comunicação IRC para receber comandos de um controlador remoto e realizar ataques de inundação de tráfego, incluindo UDP Flood e SYN Flood. Também possui funcionalidades de backdoor, como execução remota de comandos de shell e download de arquivos.